

SEC102

MENACES INFORMATIQUES ET
CODES MALVEILLANTS
ANALYSE ET LUTTE

<https://lecnam.net>

Date: 07/07/2025

Présenté par : Anthony DESSIATNIKOFF



Calendrier prévisionnel de la formation

Cours	Date	Titre	Enseignant
01	20/03/2025	Introduction à la gestion de l'incident de sécurité en entreprise	Fabrice CRASNIER
02	14/04/2025	Posture de la DSI face à un incident de sécurité	Fabrice CRASNIER
03	22/05/2025	Analyse mémoire	Maxime ROSINSKI
04	16/06/2025	Le métier de pentester et ses contraintes	Anthony DESSIATNIKOFF
05	18/06/2025	La levée de doute	Fabrice CRASNIER

Calendrier prévisionnel de la formation

Cours	Date	Titre	Enseignant
06	19/06/2025	Les méthodes d'intrusion sur les systèmes et Présentation des audits de sécurité	Anthony DESSIATNIKOFF
07	07/07/2025	Investigation sur le système	Anthony DESSIATNIKOFF
08	08/07/2025	Investigation sur le réseau	Maxime ROSINSKI
09	09/07/2025	L'investigation forensique, analyse post mortem	Fabrice CRASNIER
10	10/07/2025	L'après incident de sécurité, obligations et poursuites judiciaires	Fabrice CRASNIER

Calendrier prévisionnel de la formation

Cours	Date	Titre	Enseignant
11	11/07/2025	Analyse de malwares	Anthony DESSIATNIKOFF
12	18/08/2025	Développer un plan de remédiation après un incident de sécurité.	Maxime ROSINSKI
13	19/08/2025	Investigation, analyse et remédiation : mise en application dans l'embarqué 1/2	Maxime ROSINSKI
14	20/08/2025	Investigation, analyse et remédiation : mise en application dans l'embarqué 2/2 + Révision	Maxime ROSINSKI
15	21/08/2025	Examen	Maxime ROSINSKI

Sommaire

- ▶ Introduction
- ▶ Les différents types de journaux systèmes
- ▶ Les techniques d'analyse des journaux systèmes
- ▶ Les outils d'analyse des journaux systèmes
- ▶ Analyse Windows
- ▶ Les bonnes pratiques.
- ▶ Conclusion

- ▶ Introduction
- ▶ Les différents types de journaux systèmes
- ▶ Les techniques d'analyse des journaux systèmes
- ▶ Les outils d'analyse des journaux systèmes
- ▶ Analyse Windows
- ▶ Les bonnes pratiques.
- ▶ Conclusion

Qu'est-ce qu'un Journal Système ?

Définition :

- Un journal système est un enregistrement des événements et activités qui se produisent sur un système (ordinateur, serveur, réseau).
- Ces journaux contiennent des informations sur les connexions, les processus, les modifications de configuration et les erreurs.

Types de Journaux :

1. **Journaux de Sécurité** : Enregistrement des tentatives de connexion, échecs d'authentification, etc.
2. **Journaux des Applications** : Enregistrement des événements spécifiques aux applications (ex : accès non autorisé à une application).
3. **Journaux du Système** : Événements système comme les démarrages, les arrêts, les mises à jour.
4. **Journaux Réseau** : Données sur les connexions réseau, les tentatives d'accès, etc.

Importance de l'Analyse des Journaux pour la Sécurité

Détection des menaces :

- Les journaux permettent de repérer des comportements anormaux, signes d'une compromission.
- Exemple : Multiples tentatives de connexion échouées en peu de temps peuvent indiquer une attaque par force brute.

Traçabilité des incidents :

- Les journaux offrent une chronologie détaillée des événements, utile pour comprendre comment une attaque a eu lieu.

Conformité et audits :

- Les réglementations (comme le RGPD) exigent la conservation et l'analyse régulière des journaux pour assurer la conformité et l'intégrité des données.

Types de Menaces Détectables dans les Journaux

Attaques par force brute :

- Nombre élevé de tentatives de connexion échouées dans les journaux de sécurité.

Malwares :

- Processus inhabituels, connexions suspectes à des serveurs externes, comportements anormaux de certaines applications.

Élévation de privilèges :

- Tentatives de changement de droits d'accès ou d'accès à des ressources protégées.

Fuite de données :

- Transferts de données anormaux dans les journaux réseau, connexions vers des destinations inhabituelles.

Techniques d'Analyse des Journaux

1. Filtrage et Tri :

- Utiliser des filtres pour isoler les événements importants (ex : tentatives de connexion échouées).
- Trier par type d'événement ou par utilisateur.

2. Corrélation d'événements :

- Regrouper des événements similaires (ex : tentatives de connexion à des heures inhabituelles).
- Identifier des schémas suspects comme des accès simultanés à différents systèmes.

3. Recherche de Signatures :

- Comparer les événements à des signatures de menaces connues.
- Utiliser des outils d'analyse qui détectent les comportements similaires à ceux de logiciels malveillants.

4. Analyse en Temps Réel vs Post-Mortem :

- **En temps réel** : Détecter les menaces au moment où elles se produisent.
- **Post-mortem** : Analyser les journaux après une attaque pour comprendre les failles.

Outils d'Analyse des Journaux

SIEM (*Security Information and Event Management*) :

- Plateformes comme Splunk, IBM QRadar, et ELK Stack.
- Collecte, corrélation, et analyse en temps réel des journaux de différents systèmes.

Syslog :

- Système de journalisation utilisé sur les systèmes Linux/Unix.
- Centralisation des journaux pour faciliter l'analyse.

Scripts et Outils en Ligne de Commande :

- Utilisation de commandes comme *grep*, *awk* ou *PowerShell* pour filtrer et analyser les journaux.

Analyse Automatisée avec l'IA et le Machine Learning :

- Détection de schémas anormaux avec des algorithmes d'apprentissage automatique.

Pratiques Recommandées pour la Gestion des Journaux

Centralisation des journaux :

- Utiliser un serveur centralisé pour regrouper tous les journaux. Cela facilite l'analyse et la détection de menaces.

Conservation et Archivage :

- Conserver les journaux sur une période définie (ex : 6 mois, 1 an) selon les politiques de l'entreprise et les exigences réglementaires.

Surveillance continue et Alertes :

- Mettre en place des alertes pour des événements critiques (ex : connexions échouées répétées, tentatives d'accès à des fichiers sensibles).

Audit et Revue Régulière :

- Auditer les journaux périodiquement pour identifier les anomalies et s'assurer que les politiques de sécurité sont respectées.

Définition

Journaux systèmes (logs systèmes)

- Fichiers ou des bases de données utilisés pour enregistrer les événements qui se produisent sur un système.

Contenu

- Activités des utilisateurs
- Les opérations du système
- Les erreurs et les avertissements
- Les tentatives d'accès non autorisées
- Les changements de configuration
- etc.

16

Objectifs

La détection et la prévention d'incidents de sécurité

- Activités suspectes
- Tentatives d'accès non autorisées
- Evènements de sécurité

La réponse aux incidents de sécurité

- Comprendre les détails d'un incident
- Déterminer l'étendue de l'impact
- Évaluer les dommages causés
- Prendre des mesures appropriées

La surveillance de l'activité des utilisateurs

- Identifier les activités non conformes ou malveillantes
- Détecter les problèmes de performance ou de configuration

L'audit de conformité et de gouvernance

- Vérifier que les politiques de sécurité et de gouvernance sont respectées

L'amélioration de la performance et de la disponibilité

- Optimisation des configurations
- Identification des pannes

17 Limites et difficultés

La quantité de données

- Volumes de données très importants, ce qui peut rendre l'analyse fastidieuse et chronophage.

La diversité des formats

- Intégration et analyse parfois difficile.

Le manque de contexte

- Informations détaillées sur les événements mais il existe parfois un manque de signification si le contexte est absent.

Les faux positifs et les faux négatifs

- Des signalements d'incidents qui ne sont pas réels (faux positifs), ou alors des non-signalement sur des incidents réels (faux négatifs).

Les attaques sophistiquées

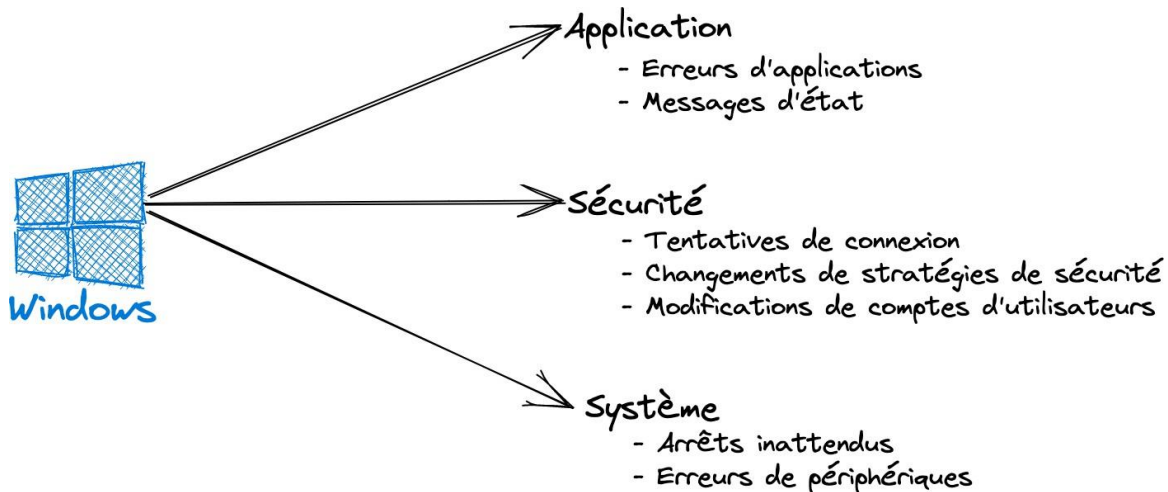
- Masquer les activités en modifiant les journaux systèmes ou utiliser des techniques d'obfuscation (Anti-forensique)

Le manque de personnel qualifié

- Nécessite des compétences techniques et des connaissances en sécurité informatique

- ▶ Introduction
- ▶ Les différents types de journaux systèmes
- ▶ Les techniques d'analyse des journaux systèmes
- ▶ Les outils de collecte et d'analyse des journaux systèmes
- ▶ Analyse Windows
- ▶ Les bonnes pratiques.
- ▶ Conclusion

Les journaux systèmes Windows



Type d'événement	Description
Error	Événement qui indique un problème significatif tel que la perte de données ou la perte de fonctionnalités. Par exemple, si un service ne parvient pas à charger au démarrage, un événement d'erreur est journalisé.
Avertissement	Événement qui n'est pas nécessairement significatif, mais peut indiquer un problème futur possible. Par exemple, lorsque l'espace disque est faible, un événement Avertissement est journalisé. Si une application peut récupérer à partir d'un événement sans perte de fonctionnalités ou de données, elle peut généralement classer l'événement en tant qu'événement d'avertissement.
Information	Événement qui décrit l'opération réussie d'une application, d'un pilote ou d'un service. Par exemple, lorsqu'un pilote réseau se charge correctement, il peut être approprié de consigner un événement Information. Notez qu'il est généralement inapproprié pour une application de bureau de journaliser un événement chaque fois qu'il démarre.
Audit des succès	Événement qui enregistre une tentative d'accès de sécurité auditée qui réussit. Par exemple, la tentative réussie d'un utilisateur de se connecter au système est enregistrée en tant qu'événement Success Audit.
Audit des échecs	Événement qui enregistre une tentative d'accès de sécurité auditée qui échoue. Par exemple, si un utilisateur tente d'accéder à un lecteur réseau et échoue, la tentative est enregistrée en tant qu'événement d'audit d'échec.

C:\Windows\System32\winevt\Logs

Numéros d'identification d'événements (Event ID).

Consultable à l'aide de l'observateur des événements Windows (mais pas que).

20

Les journaux systèmes Windows : sysmon

Surveiller et consigner l'activité système dans le journal des événements Windows.

Créations de processus

Connexions réseau

Modifications apportées à l'heure de création de fichier.

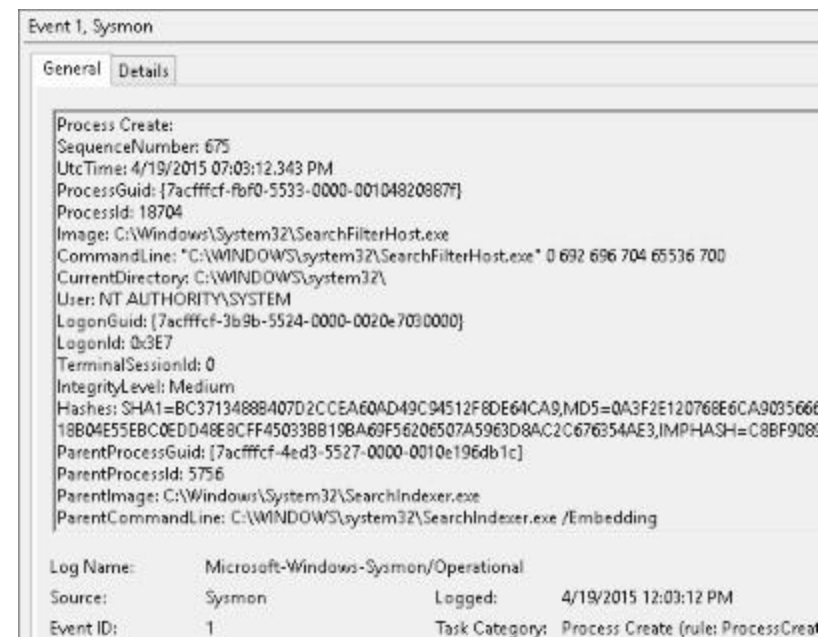
Possède ses propres ID d'événements :

1 – Création de processus

2 – Un processus modifie l'heure de création d'un fichier

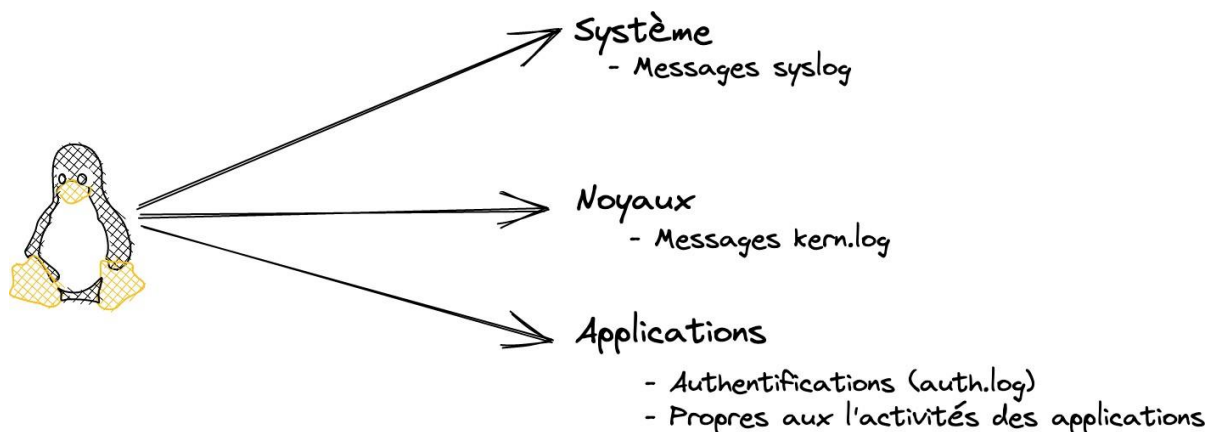
3 – Connexion réseau

Etc...



21

Les journaux systèmes Linux



```
<100>2 1982-07-10T20:30:40.001Z myserver.com su 201 32001 - BOM 'su root' failed on /dev/pts/7
```

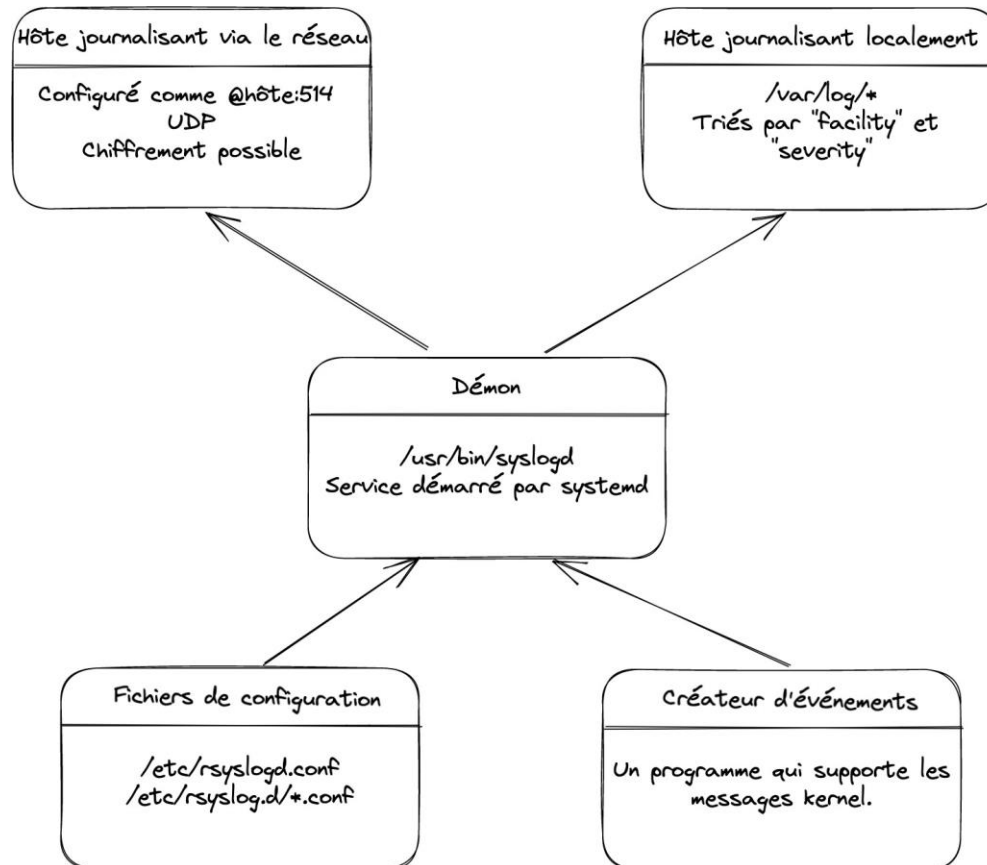
- Message: su root ...
- Encoding: BOM (UTF-8)
- Structured-Data: -
- Message ID: 32001
- Process ID: 201
- Application: su
- Hostname: myserver.com
- 30 mins and 40.0012 seconds after the 20th hour of 10 July 1982 in UTC
- Version: 2
- Priority: 34

RFC 5424 : syslog est un protocole standardisé d'échange de message au sein du système.

Stockés dans le répertoire /var/log/ par convention sur les systèmes Linux.

22

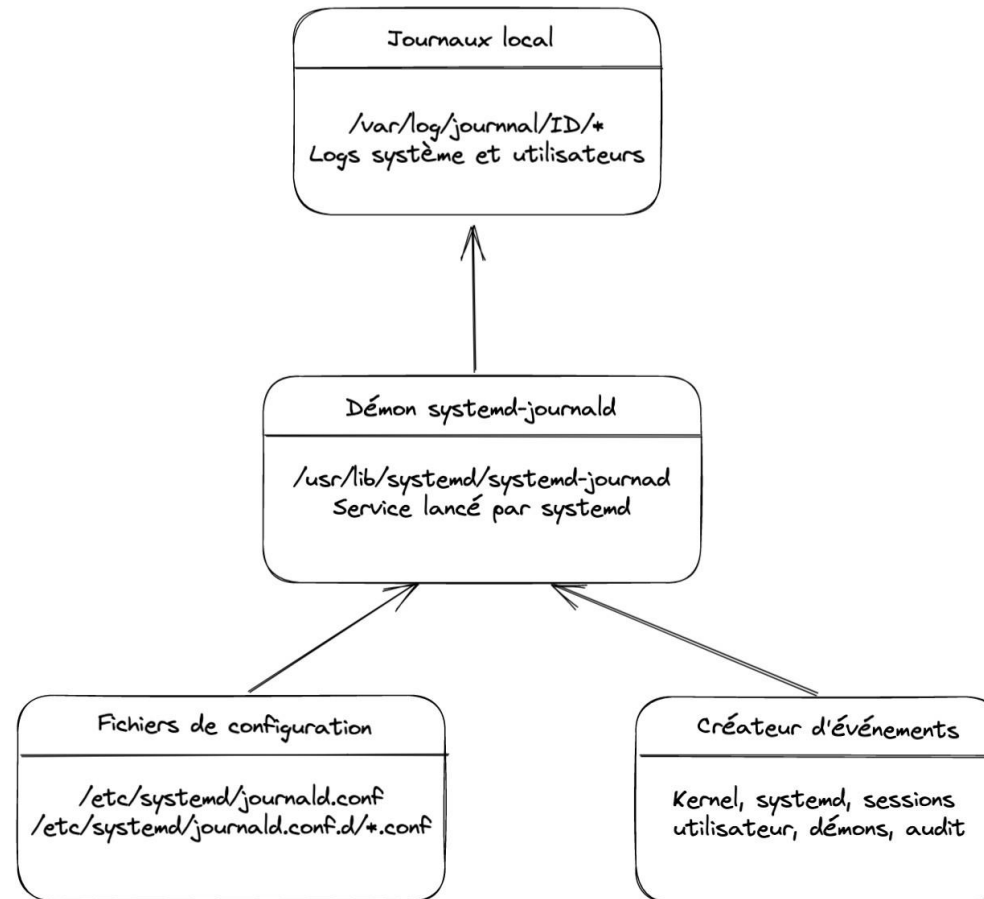
Les journaux systèmes Linux : syslogd



Facility : Permet la catégorisation des logs en fonction des sous-systèmes.

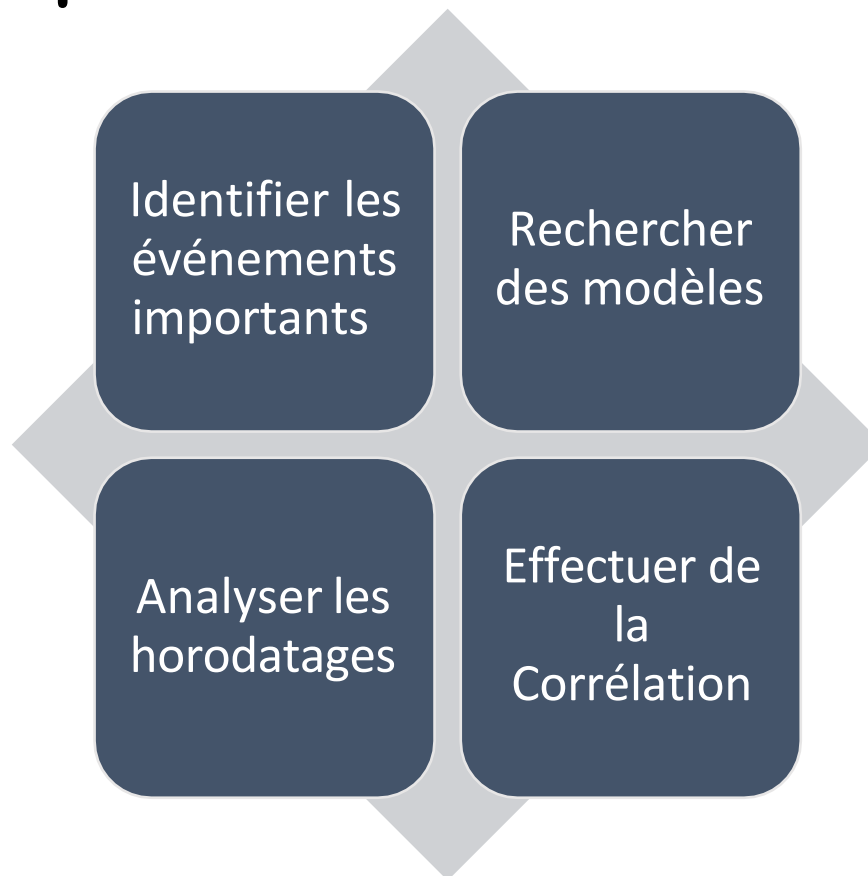
Severity : 0 – Le plus grave (priorités).

Les journaux systèmes Linux : journald



- ▶ Introduction
- ▶ Les différents types de journaux systèmes
- ▶ **Les techniques d'analyse des journaux systèmes**
- ▶ Les outils de collecte et d'analyse des journaux systèmes
- ▶ Analyse Windows
- ▶ Les bonnes pratiques.
- ▶ Conclusion

La lecture et l'interprétation des événements



Avant de vous lancer, il vous faut savoir ce que vous cherchez!

26 Les schémas d'attaques

ATT&CK®

Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control
9 techniques	10 techniques	18 techniques	13 techniques	34 techniques	16 techniques	25 techniques	9 techniques	15 techniques	16 techniques
Drive-by Compromise	Command and Scripting Interpreter (5)	Account Manipulation (2)	Abuse Elevation Control Mechanism (1)	Abuse Elevation Control Mechanism (1)	Adversary-in-the-Middle (3)	Account Discovery (3)	Exploitation of Remote Services	Adversary-in-the-Middle (3)	Application Layer Protocol (4)
Exploit Public-Facing Application	Exploitation for Client Execution	BITS Jobs	Access Token Manipulation (5)	Access Token Manipulation (5)	Brute Force (4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (3)	Communication Through Removable Media
External Remote Services	Inter-Process Communication (2)	Boot or Logon Autostart Execution (10)	Access Token Manipulation (5)	BITS Jobs	Credentials from Password Stores (3)	Browser Bookmark Discovery	Lateral Tool Transfer	Audio Capture	Data Encoding (2)
Hardware Additions	Native API	Boot or Logon Initialization Scripts (2)	Boot or Logon Autostart Execution (10)	Debugger Evasion	Exploitation for Credential Access	Debugger Evasion	Remote Service Session Hijacking (1)	Automated Collection	Data Obfuscation
Phishing (3)	Scheduled Task/Job (2)	Browser Extensions	Boot or Logon Initialization Scripts (2)	Deobfuscate/Decode Files or Information	Forced Authentication	Domain Trust Discovery	Remote Services (5)	Browser Session Hijacking	Dynamic Resolution (3)
Replication Through Removable Media	Shared Modules	Compromise Client Software Binary	Create or Modify System Process (1)	Direct Volume Access	Forge Web Credentials (2)	File and Directory Discovery	Replication Through Removable	Clipboard Data	Encrypted Channel (2)
	Software Deployment Tools		Domain Policy	Domain Policy Modification (2)	Input	Group Policy Discovery		Data from Information Repositories (1)	
	System	Create		Execution Guardrails (1)		Network Service Discovery			

Explorons ensemble la matrice, rendez-vous sur : <https://attack.mitre.org/>

- ▶ Introduction
- ▶ Les différents types de journaux systèmes
- ▶ Les techniques d'analyse des journaux systèmes
- ▶ **Les outils de collecte et d'analyse des journaux systèmes**
- ▶ Analyse Windows
- ▶ Les bonnes pratiques.
- ▶ Conclusion

28

Les outils utiles à la DSI et à la réponse à incident

Syslog-ng

Logparser

Elastic Stack

Graylog

Splunk

Wazuh

Surveillance, supervision et investigation

Pas de centralisation:

- Collecte à la main par machine.
- Perte d'informations.
- Analyse fastidieuse.

- ▶ Introduction
- ▶ Les différents types de journaux systèmes
- ▶ Les techniques d'analyse des journaux systèmes
- ▶ Les outils de collecte et d'analyse des journaux systèmes
- ▶ **Analyse Windows**
- ▶ Les bonnes pratiques.
- ▶ Conclusion

Pourquoi analyser uniquement le disque ?

- Pas toujours de capture mémoire disponible
- Post-mortem (après mise hors ligne)
- Conformité légale ou conservation de preuves

30

Artefacts principaux à examiner :

 Fichiers & dossiers clés :

- C:\Windows\Prefetch
- C:\Users\<user>\AppData\Local\Temp
- C:\Windows\System32\Tasks
- C:\ProgramData

 Clés de registre :

- Run, RunOnce
- Services
- UserAssist

 31 Logs Windows :

- winevt\Logs

30 Préparation de l'analyse

Matériel & outils :

- Image disque en lecture seule
- Autopsy, FTK Imager, X-Ways
- RegRipper, Timeline Explorer

Bonnes pratiques :

- Ne jamais modifier l'original
- Générer les hachages avant analyse

Prefetch et exécution des programmes

Le dossier Prefetch :

- Contient des fichiers .pf créés lors du premier lancement d'un exécutable
- Donne l'historique des exécutions (nom du programme, compteur d'exécution, timestamp)

Exemples d'analyse :

- Chercher des executables inattendus
- Vérifier la fréquence d'exécution

Analyse du registre

Clés à surveiller :

- Programmes lancés au démarrage
- Historique des documents ouverts (MRU, RecentDocs)
- Liste des logiciels installés

Outils :

- RegRipper
- hivex

Tâches planifiées et persistance

Pourquoi regarder les tâches ?

- Méthode courante de persistance

À examiner :

- C:\Windows\System32\Tasks
- Attributs et scripts liés

Logs Windows

Fichiers journaux :

- Sécurité (Security.evtx)
- Système (System.evtx)
- Application (Application.evtx)

Éléments recherchés :

- Nouvelles installations
- Connexions RDP
- Activités inattendues

Timeline et corrélation

Créer une chronologie :

- Combiner Prefetch, MFT, logs
- Identifier la séquence des événements

Outils :

- Plaso/log2timeline
- Timeline Explorer

Livrables et rapport

Contenu attendu :

- Liste des artefacts et fichiers suspects
- Timestamps détaillés
- Hypothèse d'infection ou de compromission
- IOC (hashs, chemins)
- Recommandations (correctives et préventives)

- ▶ Introduction
- ▶ Les différents types de journaux systèmes
- ▶ Les techniques d'analyse des journaux systèmes
- ▶ Les outils de collecte et d'analyse des journaux systèmes
- ▶ Analyse Windows
- ▶ **Les bonnes pratiques.**
- ▶ Conclusion

Mettre en place une **stratégie de détection** :

- Stratégie d'analyse : Identifier les valeurs métier, les événements redoutés ainsi que les scénarios d'attaques stratégiques et opérationnels
- Stratégie de collecte : Identifier les machines que vous souhaitez collecter ainsi que le type d'événements et la manière de les journaliser.

Recommandations de sécurité pour l'architecture d'un système de journalisation :

<https://cyber.gouv.fr/publications/recommandations-de-securite-pour-larchitecture-dun-systeme-de-journalisation>

Recommandations de sécurité pour la journalisation des systèmes Microsoft Windows en environnement Active Directory :

<https://cyber.gouv.fr/publications/recommandations-de-securite-pour-la-journalisation-des-systemes-microsoft-windows-en>

- ▶ Introduction
- ▶ Les différents types de journaux systèmes
- ▶ Les techniques d'analyse des journaux systèmes
- ▶ Les outils d'analyse des journaux systèmes
- ▶ Les bonnes pratiques de l'analyse des journaux systèmes
- ▶ Conclusion

Conclusion

Points Clés à Retenir :

- **Importance des journaux systèmes** : Les journaux sont essentiels pour détecter, comprendre et réagir face aux incidents de sécurité. Ils constituent une source précieuse d'informations sur l'activité des systèmes.
- **Détection des menaces** : L'analyse des journaux permet d'identifier des comportements anormaux (ex. : tentatives de connexion, accès non autorisés, activités réseau suspectes) qui peuvent indiquer la présence de malwares ou d'intrusions.
- **Outils et Techniques d'Analyse** : Utiliser des outils comme les plateformes SIEM, les scripts de traitement, et les méthodes de corrélation d'événements pour extraire et analyser les données critiques dans les journaux.
- **Pratiques Recommandées** : Centraliser les journaux, mettre en place des alertes en temps réel, et effectuer des revues régulières pour renforcer la sécurité et améliorer la capacité de réponse aux incidents.